CtrlPay — Red-Team Test Matrix (T-01 … T-10)

Purpose. Map every red-team check requested in the FinTechathon security review to an **executable regression test** in this repository. Nothing below is a manual-only claim.

Run everything with:

```
npm test
```

> Sandbox note: CtrlPay moves no real funds. The ledger, the Master Switch and the AI mandate are user-owned sandbox state. These tests prove that the **server-side boundaries** (signature, tenant, tier gate, floors, settlement) behave as specified; they do not claim production-grade identity or durable storage (see `SECURITY_REPORT.md` residual risks).

ID	Attack / failure scenario	Automated proof	What it proves
T-01	Master Switch OFF, then a direct T3 approval request	`tests/red-team.test.ts` → *Master Switch OFF rejects a T3 approval with 403 and a BLOCKED audit entry*; `tests/permissions.test.ts`	HTTP **403** `TIER_BLOCKED`; audit entry status **BLOCKED** with `actionType = T3_GATE_REJECTED_MASTER_AUTONOMY_OFF`.
T-02	Tamper any signed proposal term (e.g. reward +RM 0.01)	`tests/proposal-stateless.test.ts` → *rejects a proposal whose premiumReward was tampered with by 0.01*; `tests/proposals.test.ts`	HMAC integrity failure → **409** `INTEGRITY_HASH_MISMATCH`; no state change.
T-03	Double-claim a Quarantine reward / claim before maturity	`tests/store.test.ts` → *impossible to claim a reward before +24h, is idempotent: a second claim cannot drain the rewardPool again*	Claim is refused before `READY_TO_DECIDE`; a second claim leaves `defenseVault` and `rewardPool` unchanged.
T-04	Lock NEEDS categories; exceed 40 % / RM 15 floor / AI mandate; direct NEEDS Quarantine	`tests/quant-engine.test.ts`; `tests/proposals.test.ts`; `tests/red-team.test.ts` → *a direct API call cannot create a NEEDS-category Quarantine*	NEEDS escrow rejected (`NEEDS_CATEGORY_LOCKED`); reduction capped at `min(40 % × DDA, DDA − RM 15)`; direct API NEEDS Quarantine → **400** `NEEDS_NOT_QUARANTINABLE`.
T-05	Non-reproducible CFaR / hidden low-history risk	`tests/quant-engine.test.ts` → *is deterministic for the same seed*	Same seed ⇒ identical bootstrap output; `lowHistoryWarning` is surfaced when history < 14 days.

ID	Attack / failure scenario	Automated proof	What it proves
T-06	Credit sweep savings before the merchant charge actually stops	`tests/store.test.ts` → *credits a pending sweep ONLY after its billing date is crossed (two-stage settlement)*; `tests/generate-execution-evidence.test.ts`	Stage 1 creates `PENDING_NEXT_BILLING_VERIFICATION` with **zero** vault credit; stage 2 credits only after the billing date.
T-07	Cross-tenant proposal / audit access	`tests/proposals.test.ts` → *rejects a decision from another tenant*; `tests/audit-logger.test.ts` → tenant isolation; `tests/session.test.ts`	Server-side userId comes only from the signed session cookie; another tenant receives **403 FORBIDDEN**; audit chains are per user.
T-08	Mutate an earlier audit entry to hide an action	`tests/audit-logger.test.ts` → `verifyChain()` tamper detection	Any edited field breaks the hash chain; the drawer shows **chain tampered**; restoring re-hashes from genesis.
T-09	Click "Jump to Month-End" repeatedly to duplicate settlement	`tests/store.test.ts` → *is idempotent: a second Jump to Month-End does not move the clock or credit again*	The clock does not advance twice and `defenseVault` / `rewardPool` are unchanged on the second click.
T-10	LLM hallucinates an RM figure not produced by the engine	`tests/privacy-guard.test.ts`; `tests/audit-logger.test.ts` (`NUMBER_VERIFIER_BLOCKED`)	`verifyNumbers()` flags unverified RM figures; the chat route records `NUMBER_VERIFIER_BLOCKED` with `data_accessed = ['engine.outputs', 'ledger']`.

Boundary checks added in this review

Check	Test	Expected result
Malformed autonomy payload (missing `enabledTiers`)	`tests/red-team.test.ts`	**400** `INVALID_AUTONOMY` (never a 500 / silent default).
Unknown escrow category	`tests/red-team.test.ts`	**400** `INVALID_INPUT` (no uncaught `ZodError`).
Reserved `.example` mailto recipient	`tests/subscription-registry.test.ts`	Flagged by `isDemoPlaceholderAddress()` and labelled in the cancellation sheet.

Known residual limits (not automated away)

- Sandbox identity is a **signed cookie**, not a production login; the demo tenant is used when no cookie exists.
- Proposal status / replay protection is **in-memory**; stateless cold starts re-verify the HMAC but cannot see another instance's settled status. Production requires a durable proposal table.

- The number verifier **flags and audit-logs** unverified figures after the stream completes; it cannot retract bytes already streamed. Production should buffer or tool-gate every financial figure.
- The Anytime Fitness mailto address is a labelled **demo placeholder**, not a live merchant mailbox.